

DoughBoss — Technical Plan

Real-time ordering platform: architecture, backlog, schema & build

Prepared for the dev team · 17 June 2026 · Based on an 11-agent code & live-site audit

1. Current state (live screening)

Area	Finding
Stack	WP 7.0, PHP 8.2.31, child theme <code>doughboss-child</code> (parent <code>doughboss</code>). Plugin DoughBoss active, REST healthy.
Launch state	0 menu items, 0 orders, no page contains the <code>[doughboss...]</code> shortcodes — storefront not surfaced.
Localisation	<code>currency=USD</code> (should be AUD); <code>tax_rate=0</code> (AU GST 10% inclusive); no timezone; <code>admin_email = dev agency</code> .
Perf	Homepage loads jQuery 3.5.1 from Google CDN (render-blocking).
Data model	Custom tables <code>wp_doughboss_orders</code> / <code>_order_items</code> ; 8-status lifecycle; no shop/location dimension; no payment fields.

2. Target architecture

WordPress remains the system of record and REST surface. Layer an **event-driven realtime path** on the existing `doughboss_order_*` action hooks: on order creation, fan out to managed pub/sub **plus** server-side side-effects (SMS, print) that fire independent of any screen. The Kitchen Display is an installable PWA on a locked shop tablet. Introduce provider interfaces (`PaymentGateway`, `Notifier`, `OrderRepository`, `FulfilmentChannel`) behind a PSR-4 namespace + DI container so Stripe / Ably / PrintNode / Twilio are swappable and testable. A `shop_id` dimension and a versioned migration runner are the foundation.

3. Prioritised backlog

Pri	Item	Effort
P0	Transaction-wrap order+items create with checked inserts + rollback DONE v2.1.0	S
P0	Versioned migration runner; DB schema bump DONE v2.1.0	M
P0	Idempotency-Key on <code>/checkout</code> DONE v2.1.0 (storefront JS to send key — follow-up)	S

P0	Longer order numbers + insert-retry on collision DONE v2.1.0	S
P0	Reconfigure AUD + GST-inclusive math (<code>tax = total/11</code>)	S
P0	Rate-limit + harden public <code>track_order</code> (drop <code>__return_true</code> , signed token)	S
P1	Live order board / KDS feed + screen DONE v2.1.0 (polling MVP)	M
P1	Managed realtime transport (Ably/Pusher) + customer live tracking	M
P1	Stripe PaymentIntents (AUD, GST, SAQ-A) + webhook auto-confirm	L
P1	Store-hours / scheduling enforcement	L
P1	A11y: focus styles, replace <code>alert()</code> with <code>aria-live</code> , contrast	M
P2	Multi-shop schema + delivery-zone routing + per-shop menus	L
P2	PrintNode receipt printing + Twilio SMS	L
P2	Indexes, cached COUNT, fix admin N+1, status-history + sales rollups	M
P2	Composer + PHPUnit + phpcs + CI; namespaces/DI; provider interfaces	M

4. Real-time orders → shop

Decision of record. Transport: **Ably primary + 5s REST poll fallback** (shared hosting can't hold WS/SSE; since= cursor + acknowledged_at make replays idempotent). Surface: **installable PWA on a locked tablet** (not wp-admin). Staff auth: **per-device Application Passwords / short JWT scoped to a kds_operator role** (manage_doughboss_kds, never manage_options); Ably tokens minted per shop. Alerting: **looping Web Audio chime + full-screen banner until acknowledged + Web Push + server-side Twilio SMS**. Printing: **PrintNode fired server-side**. Routing: **shop_id ; delivery by postcode/ suburb, pickup = chosen shop**.

Sequence

```
customer checkout → POST /checkout → DoughBoss_Order::create() (status=pending)
  → doughboss_order_created fires
  → listener resolves shop, publishes order.new to shop:{id} (Ably) + enqueues SMS + print job
  → KDS card appears, chime loops + banner until staff Acknowledge
  → staff Accept + ETA → POST /kds/order/{id}/accept → status=confirmed, eta stored
  → doughboss_order_status_changed → republish order.update
  → customer tracker (subscribed to order:{number}) updates live
  → fallback: KDS polls /admin/orders every 5s; tracker polls /order/{number} every 10s
```

5. Data model & schema changes

Migration runner is the prerequisite for all of these.

- orders new columns: `eta_minutes, seen_at, acknowledged_at, accepted_at (v2.1.0)`; then `shop_id, payment_status, payment_intent_id, payment_method, paid_at, ready_at`; change currency default → AUD.
- order_items: add `shop_id`.
- New tables: `wp_doughboss_shops, wp_doughboss_order_status_history, wp_doughboss_shop_hours, wp_doughboss_delivery_zones, wp_doughboss_shop_items, wp_doughboss_sales_daily`.
- New REST: `GET /admin/orders, POST /admin/order/{id}/ack, POST /admin/order/{id}/accept (v2.1.0)`; then `POST /doughboss/v1/stripe/webhook, /kds/*`.
- New hooks: `doughboss_order_accepted (v2.1.0), doughboss_order_eta_set, doughboss_order_paid`; existing `doughboss_order_created/_status_changed` drive a single `Realtime::publish()` fan-out.

6. Payments & AU tax

- Stripe **PaymentIntents + Payment Element** → PCI **SAQ-A** (no card data on server); Apple/Google Pay/Link automatic.
- Flow: order created `pending_payment` → server `PaymentIntent` (currency: aud, idempotency key = `order_number, metadata.order_id`) → client confirm → **signature-verified webhook is the sole source of "paid"**; email only on paid.

- AU tax: set **AUD**, GST **inclusive** ($\text{tax} = \text{round}(\text{total}/11, 2)$, not $\text{subtotal} * 0.10$); Tax Invoice with ABN + GST line ($\geq \text{A\$82.50}$). Optional pay-on-pickup; capped card surcharge.
- On `doughboss_order_paid` → push tax invoice to Xero/Zoho. Stripe Radar + 3DS automatic.

7. Security findings (key)

Sev	Finding	Fix
HIGH	<code>track_order</code> <code>__return_true</code> , unthrottled; short order numbers → enumeration/PII harvest	Rate-limit, signed tracking token, longer numbers (numbers widened in v2.1.0)
MED	Cart token taken verbatim from cookie (poisoning / transient exhaustion)	HMAC-sign + rotate on checkout; cap transients/IP
MED	Nonce-only gate on checkout (scriptable) before payments	Throttle/honeypot; re-validate prices server-side (already done)
LOW	Two <code>innerHTML</code> sinks in storefront JS; uninstall not multisite-aware	Use <code>textContent</code> ; <code>get_sites()</code> loop (board JS uses <code>textContent</code>)

Note: server-side pricing, prepared SQL, whitelisted ORDER BY and capability-gated admin screens are already correct.

8. Frontend / UX / a11y

- **CRIT** No focus indicators; errors via `alert()`; loaders not announced — WCAG blockers. Add `:focus-visible`, `aria-live` errors, `role=status`.
- **HIGH** Colour contrast fails AA (muted text, white-on-accent); no sticky cart/upsell.
- **MED** Menu images via CSS background (no alt/lazy/srcset); raw price formatting → use `Intl.NumberFormat('en-AU', {currency: 'AUD'})`.
- Move jQuery off Google CDN (render-block) — dequeue in child theme.

9. Scalability & multi-shop

- Single-tenant today: global settings + global menu + location-less orders. Add `doughboss_locations` + per-shop config + `location_id` on orders.
- Indexing: `KEY(shop_id, status, created_at)`, `KEY(created_at)`; fulltext or filter-first search; cache `COUNT(*)`; fix admin `get_items()` N+1.
- Caching: exclude storefront/tracking from page cache; cache `/menu` + `/config` per location; short `Cache-Control` on tracking.
- Reporting: `order_status_history` + nightly `sales_daily` rollup → sales/AOV/item-mix/peak; CSV + Xero/Zoho export.

10. Growth instrumentation

- Dual tracking: browser pixels (Meta/TikTok/GA4) + **server-side Meta CAPI / TikTok Events API fired from the order hooks**; dedup by `event_id = order_id`; hashed email/phone.
- First-party Custom Audiences + Lookalikes from owned order data — the marketing moat.
- AU Privacy Act: consent banner (no pre-tick) gating browser pixels.

- Tooling map: order hooks → CAPI/Events; Zapier → audience sync/posting/review-requests; WPVibe → schema/meta/pages; Canva+Adobe → creative; deep-research → keywords; GA4 → measurement.

11. Phase 1 delivered — v2.1.0

Shipped on branch `claude/funny-goodall-gsoog4` (PR #2), installable via **Plugins** → **Add New** → **Upload Plugin** → **Replace current**.

- **Live Order Board** (`admin/class-doughboss-admin.php` + `public/js/doughboss-orderboard.js` + `.css`): standalone screen polling `GET /admin/orders` every 7s; New / Preparing / Ready lanes; looping Web Audio chime + visual alert until **Acknowledge**; one-tap Accept (ETA chips) + status advance; tablet-friendly, focus-visible, `textContent` rendering.
- **Kitchen role**: `doughboss_kitchen` role + `manage_doughboss_kds` cap (no full admin login on a device).
- **Pipeline hardening**: transactional `create()` with rollback; order-number widening + retry; `/checkout` Idempotency-Key; versioned migration runner (DB 1.1.0; additive columns via `dbDelta`).
- **New endpoints**: `GET /admin/orders`, `POST /admin/order/{id}/ack`, `POST /admin/order/{id}/accept`. Orders gain ETA + seen/acknowledged/accepted timestamps; `doughboss_order_accepted` hook.

How to test

```
1. Upload zip / install branch → activate (migration auto-adds columns + role).
2. Open "Order Board" → click "Enable sound alerts".
3. Place a test order from the storefront.
4. Card appears within ~7s with a chime → Accept (ETA) → advance status.
5. Optional: create a DoughBoss Kitchen user → confirm board-only access.
```

12. Risks & mitigations

Risk	Mitigation
Non-transactional writes corrupt revenue/ reports	Transaction + checked inserts + rollback DONE
Tablet asleep/offline drops live orders	Server-side SMS + print independent of screen; chime loops; <code>since=</code> reconcile
Shared-host realtime instability	Managed pub/sub off-box + always-on poll fallback + idempotent <code>order.new</code>
Payment/order desync, double-charge	Idempotency key = <code>order_number</code> ; webhook sole "paid" source; email only on paid
Auth leakage / order enumeration	Low-priv <code>kds_operator</code> ; per-shop scoped tokens; rate-limited + signed tracking

Appendix — REST endpoints

Method	Endpoint	Purpose
--------	----------	---------

GET	/config, /menu	Storefront config + items (public)
GET/POST	/cart, /cart/add update remove clear	Guest cart (nonce)
POST	/checkout	Create order (nonce; Idempotency-Key)
GET	/order/{number}?email=	Customer tracking
POST	/admin/order/{id}/status	Staff status (cap)
GET	/admin/orders	Order board feed (cap) NEW
POST	/admin/order/{id}/ack	Acknowledge (cap) NEW
POST	/admin/order/{id}/accept	Accept + ETA (cap) NEW